Control AI Agent Tools with OCI IAM Application Roles

OUT1015 Self-Paced Lab: Activity Guide

Table of Contents

Control AI Agent Tools with OCI IAM Application Roles....1
Introduction....3
Overview....3
What You Use....3
Objectives....3
Get Started....5
Prerequisites....5
How to Read This Guide....5
Practice 1-1: Build the Starting State....6
Prepare the Identity Domain....6
Start the Order Tools on Your Laptop....7
Practice 1-2: Sign In and View the Order....8
Practice 1-3: Try to Cancel the Order....9
Practice 1-4: Grant the Cancellation Role....10
Practice 1-5: Cancel Again with a New Token....11
Checkpoint: What You Proved....11
Repeat the Practices....12
Troubleshooting....13
Practice 1-6: Clean Up Your Tenancy....14
Acknowledgements....15

Copyright © 2026, Oracle and/or its affiliates.

Introduction

Overview

At Oracle AI World you watched this as an instructor demonstration. This guide lets you repeat it with an identity domain in your own OCI tenancy and a small app on your laptop.

Summit Retail's support agents use order tools through the Model Context Protocol (MCP). An MCP server offers tools such as `view_order` and `cancel_order` to a client, which can be an AI assistant or, as here, a simple web page. Asha can see both tools, but seeing a tool is not permission to use it. Each tool call carries Asha's OCI IAM access token, and the MCP server checks the application roles in that token on every call.

In this lab you play Asha. You sign in with your own identity domain user, view an order, try to cancel it, and see the server refuse. Then, as the administrator, you grant one application role in the Console and try again, without changing any code.

Estimated time: 45 minutes: 15 minutes of setup, 20 minutes of practices, and 10 minutes of clean-up.

What You Use

Part	Where	Purpose
`setup.py`	OCI Cloud Shell	Creates the two integrated applications, the two application roles, and the grants in your identity domain.
Integrated app `Summit Orders MCP Resource (lab)`	Identity domain	Represents the order service. Owns the roles `OrderViewer` and `OrderCanceller`, and the scope `/orders.invoke`.
Integrated app `Summit Orders MCP Client (lab)`	Identity domain	The sign-in client for the page on your laptop.
MCP order service	Your laptop, port 8892	Offers `view_order` and `cancel_order`, and checks the role on every call. Holds one synthetic order, SR-1042.
Order page	Your laptop, port 8891	Signs you in with OCI IAM and calls the MCP tools for you.

Objectives

- Sign in with OCI IAM and call an MCP tool with a user access token.

Copyright © 2026, Oracle and/or its affiliates.

- See the MCP server refuse a tool the user's token does not authorize, without changing the order.
- Grant an application role in the Console, and see the same tool succeed with a new token.

Copyright © 2026, Oracle and/or its affiliates.

Get Started

Prerequisites

- An OCI tenancy in which you are an identity domain administrator. The lab uses the `Default` domain unless you choose another one.
- A laptop with Python 3.10 or later and a web browser. The services run only on your laptop at `127.0.0.1`; nothing is exposed to the internet.
- Ports 8891 and 8892 free on your laptop.
- No charges: the lab creates only identity domain objects.

How to Read This Guide

You see	It means
Bold text	Text you click or select in the Console or on the order page.
`Code text`	A value you type, or a name you look for.
A dark box	Commands to run. Each task says whether in Cloud Shell or on your laptop. Lines after the box show the expected output.
Expected result	What to check before you move on.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-1: Build the Starting State

A script prepares your identity domain, and a small package runs the order tools on your laptop. At the end, your user has the `OrderViewer` role but not `OrderCanceller`.

Estimated time: 15 minutes.

Prepare the Identity Domain

1. Sign in to the OCI Console. In the Console header, click the **Developer tools** icon, and select **Cloud Shell**.

2. Download and extract the package:

```
$ REPO=https://github.com/SaurabhOCI/aiworld-2026-zero-trust-labs
$ ZIP=aiw-mcp-lab.zip
$ wget -q -O ~/$ZIP $REPO/raw/main/self-paced/$ZIP
$ unzip -o -q ~/$ZIP -d ~/aiw-mcp-lab && cd ~/aiw-mcp-lab
$ ls
```

```
README.md  laptop  setup.py
```

3. Run the build. By default it uses the `Default` domain and makes **you** the lab user:

```
$ python3 setup.py build
```

```
[..] Created Summit Orders MCP Resource (lab)
[..] Created Summit Orders MCP Client (lab)
[..] Created OrderViewer
[..] Created OrderCanceller
...
[..] Wrote mcp-lab-config.json. Download it to your laptop ...
Lab user <your-username>: OrderViewer
MCP lab: STARTING STATE (Viewer only)
```

> **Note**
>
> To use another domain or user, add `--domain <domain-name>` or `--user <username>`. The user must be able to sign in to that domain with a password.
>
> If your `Default` domain shows the type **Light weight** and has no **Integrated applications** tab, it cannot hold the two applications. Use another domain, and a user in that domain, for example: `python3 setup.py build --domain Test-Domain --user summit-asha`. Create the user first in that domain's **User management** tab, and set its password from the activation email.
>
> If an application with the same name already exists, the build stops rather than change it.

Copyright © 2026, Oracle and/or its affiliates.

4. Download the configuration file. In the Cloud Shell window, click **Menu**, select **Download**, enter `aiw-mcp-lab/mcp-lab-config.json`, and click **Download**.

> **Note**
>
> The file holds the client secret for the lab client application. Keep it private, and delete it when you finish the lab.

Start the Order Tools on Your Laptop

1. On your laptop, open a terminal, and download and extract the same package:

```
$ REPO=https://github.com/SaurabhOCI/aiworld-2026-zero-trust-labs
$ ZIP=aiw-mcp-lab.zip
$ curl -sL -o $ZIP $REPO/raw/main/self-paced/$ZIP
$ unzip -o -q $ZIP -d aiw-mcp-lab && cd aiw-mcp-lab/laptop
```

2. Create a Python environment, and install the requirements:

```
$ python3 -m venv .venv
$ . .venv/bin/activate
$ pip install -q -r requirements.txt
```

> **Note**
>
> On Windows, run `py -m venv .venv` and `.venv\Scripts\activate`, and use `py` instead of `python3` in the rest of this guide.

3. Start the services with the configuration file you downloaded:

```
$ python3 start.py --config ~/Downloads/mcp-lab-config.json
```

```
Config installed. You can delete the downloaded copy.
...
Open http://127.0.0.1:8891/ in a private browser window.
Press Ctrl+C here to stop.
```

4. Leave the terminal running. Delete the downloaded `mcp-lab-config.json`; `start.py` keeps its own copy in the `.local` folder.

> **Expected result**
>
> Cloud Shell shows `MCP lab: STARTING STATE (Viewer only)`, and your laptop terminal shows `Press Ctrl+C here to stop.`. You can run `python3 setup.py status` in Cloud Shell at any time to see which order roles your user holds.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-2: Sign In and View the Order

A customer wants to know whether their backpack has shipped. Asha checks order SR-1042, and then the customer asks to cancel it. You see what the MCP server allows with Asha's current roles, change her roles centrally, and try again.

Estimated time for Practices 1-2 to 1-5: 20 minutes.

1. Open a **private** browser window, and go to `http://127.0.0.1:8891/`. A private window keeps the sign-in separate from your Console session.

2. Click **Continue with Oracle SSO**. Sign in with the lab user's username and password on the Oracle sign-in page.

3. Back on the order page, click **View order**.

> **Expected result**
>
> The page shows `Order viewed successfully.` and SR-1042, Everyday Backpack, **Pending**, order version 1.
>
> The **Behind the scenes** panel shows the token role `OrderViewer`, both tools available, and the server decision `ORDER_VIEWED`.

> **Note**
>
> The MCP server lists both tools, `view_order` and `cancel_order`, because listing a tool is not a security decision. The decision happens when a tool is called.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-3: Try to Cancel the Order

1. Click **Cancel order**, and then **Confirm cancellation**.

> **Expected result**
>
> The page shows `Cancellation not permitted. Your account does not have the cancellation role.`
>
> The panel shows the required role `OrderCanceller`, the server decision `ORDER_PERMISSION_DENIED`, and **Order changed: No**. The order is still Pending, version 1.

> **Note**
>
> If you see a sign-in, expiry, or connection message instead, click **Reconnect order tools** and try again. Only `ORDER_PERMISSION_DENIED` is the denial this task looks for.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-4: Grant the Cancellation Role

Now act as the administrator. You change Asha's grant in the identity domain; you do not touch the code or the MCP server.

1. In the OCI Console, open the navigation menu, and select **Identity & Security** > **Domains**. Click the domain you used in Practice 1-1 (by default `Default`).
2. Click the **Integrated applications** tab, and click `Summit Orders MCP Resource (lab)`.
3. Click the **Application roles** tab. In the row for `OrderCanceller`, click the **Actions** menu (three dots), and select **Manage users**.
4. In **Manage user assignments**, click **Assign users**, select the lab user, and click **Assign**. Then click **Close**.

> **Expected result**
>
> The `OrderCanceller` row shows 1 assigned user. In Cloud Shell, `python3 setup.py status` now lists `OrderCanceller, OrderViewer`.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-5: Cancel Again with a New Token

The MCP server reads Asha's roles from her access token. Her current token was issued before the grant, so it still carries only `OrderViewer`. The grant takes effect with her next token.

1. On the order page, click **Reconnect order tools**, and complete the sign-in again if asked.
2. Click **View order**, then **Cancel order**, and **Confirm cancellation**.

> **Expected result**
>
> The page shows `Order SR-1042 has been cancelled.` The order is **Cancelled**, version 2.
>
> The panel shows the token roles `OrderCanceller` and `OrderViewer`, and the server decision `ORDER_CANCELLED`.

Checkpoint: What You Proved

Question	Before the grant	After the grant
Can Asha see the cancel tool?	Yes	Yes
Can she view SR-1042?	Yes (OrderViewer)	Yes
Can she cancel SR-1042?	No: ORDER_PERMISSION_DENIED, order unchanged	Yes, with a new token: ORDER_CANCELLED
What changed?	-	One application role grant, in the identity domain

- Why did Asha have to reconnect after the grant?
- OCI IAM policies such as `Allow group ... to manage instances` did not appear in this lab. Why not?

> **Checkpoint**
>
> **1.** The MCP server checks the roles in the access token. Her old token was issued before the grant and did not carry `OrderCanceller`, so she needed a new token. Short token lifetimes (5 minutes in this lab) limit how long an old grant keeps working after you remove it.
>
> **2.** OCI IAM policies control OCI resources such as instances and buckets. A custom API like this order service is protected by an integrated application and its application roles, which the API checks itself.

Copyright © 2026, Oracle and/or its affiliates.

Repeat the Practices

To start again, remove the cancellation role in Cloud Shell, and put the order back to Pending on your laptop:

```
$ cd ~/aiw-mcp-lab
$ python3 setup.py reset
```

```
[..] Removed the OrderCanceller grant
Lab user <your-username>: OrderViewer
MCP lab: STARTING STATE (Viewer only)
```

1. On your laptop, stop the services with **Ctrl+C**, and start them with the order reset:

```
$ python3 start.py --reset-orders
```

```
Orders reset: SR-1042 starts again as Pending, version 1.
...
```

2. On the order page, click **Disconnect order tools**, and close the private window.

Copyright © 2026, Oracle and/or its affiliates.

Troubleshooting

- `The lab user was not found in this domain`: you signed in to the Console with a user from another domain. Run the build with `--domain <domain-name>` and `--user <username>`.
- The Oracle sign-in page shows an error about the redirect URL or the client: check that you opened `http://127.0.0.1:8891/` exactly, not `localhost`.
- The page says your connection has expired: tokens last 5 minutes. Click **Reconnect order tools**.
- `Address already in use`: another program uses port 8891 or 8892. Stop it, or stop an earlier `start.py` with **Ctrl+C**.
- `No config yet`: run `start.py` once with `--config <path to mcp-lab-config.json>`.
- The cancellation is still denied after the grant and a reconnect: run `python3 setup.py status` in Cloud Shell to check the grant, then sign out of the private window and sign in again.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-6: Clean Up Your Tenancy

1. On your laptop, stop the services with **Ctrl+C**, and delete the `aiw-mcp-lab` folder. It contains the client secret in `laptop/.local`.

2. In Cloud Shell, remove everything the setup created, including any role grant you added in the Console:

```
$ cd ~/aiw-mcp-lab
$ python3 setup.py teardown --yes
```

```
[..] Deleted role claim
[..] Deleted OrderViewer
[..] Deleted OrderCanceller
[..] Deleted Summit Orders MCP Client (lab)
[..] Deleted Summit Orders MCP Resource (lab)
[..] Teardown complete.
Delete mcp-lab-config.json from your laptop as well.
```

Copyright © 2026, Oracle and/or its affiliates.

Acknowledgements

- **Author:** Saurabh Patil, Principal OCI Instructor, Oracle University
- **Workshop:** OUT1015 Zero Trust Security with OCI, Oracle AI World 2026
- **Last updated:** October 2026

Copyright © 2026, Oracle and/or its affiliates.